

RAPORT OCENY PODATNOŚCI

Vulnerability Assessment Report

Analiza podatności systemu Metasploitable 3

Środowisko laboratoryjne — Ubuntu 14.04 LTS

Analitik: Bartłomiej Kapala

Narzędzia: OpenVAS / Greenbone · Nessus Essentials

Data: lipiec 2026

1. Metryka oceny

Analityk	Bartłomiej Kapała
Cel oceny	Metasploitable 3 (ub1404), 192.168.47.7
System operacyjny	Ubuntu 14.04 LTS, kernel 3.13.0-24-generic
Data analizy	lipiec 2026
Narzędzia	OpenVAS / Greenbone, Nessus Essentials
Standardy	CVE · CVSS · NIST SP 800-115
Klasyfikacja	Ocena laboratoryjna (środowisko testowe)

2. Streszczenie wykonawcze

W lipcu 2026 przeprowadzono ocenę podatności systemu testowego **Metasploitable 3** przy użyciu dwóch niezależnych skanerów — **OpenVAS** oraz **Nessus**. Zastosowanie dwóch narzędzi umożliwiło korelację wyników i weryfikację wykrytych podatności. Poniżej zestawiono rozkład znalezisk według istotności (severity) i narzędzia:

Severity	OpenVAS	Nessus
Critical	3	3
High	3	2
Medium	10	8
Low	3	4
Log / Info	38	81

Najpoważniejsze znaleziska to dwie podatności umożliwiające **zdalne wykonanie kodu (RCE)** o maksymalnej istotności CVSS 10.0, potwierdzone przez oba skanery. Rozbieżność liczbowa między narzędziami jest zjawiskiem normalnym i wynika z:

- różnych baz testów (OpenVAS NVT vs. pluginy Nessus),
- odmiennych domyślnych polityk skanowania,
- różnych progów detekcji i modeli scoringu,
- różnic w klasyfikacji istotności.

3. Zakres i metodyka

Zakres

Ocenie poddano pojedynczy host 192.168.47.7 (Metasploitable 3, Ubuntu 14.04 LTS) w izolowanej sieci host-only 192.168.47.0/24. Maszyną skanującą był Kali GNU/Linux (192.168.47.5). Skan miał charakter niewierzytelniony (unauthenticated) — bez podania poświadczeń do systemu celu; w Nessusie odnotowano status uwierzytelnienia „Fail”, co potwierdza brak dostępu na poziomie konta.

Metodyka

Zastosowano dwa niezależne skanery podatności w celu korelacji wyników:

- **OpenVAS / Greenbone Vulnerability Management** — polityka „Full and fast”, próg jakości detekcji QoD $\geq 70\%$.
- **Nessus Essentials** — polityka „Basic Network Scan”, scoring CVSS v3.0.

Ocenę oparto na powszechnie przyjętych standardach: identyfikacja podatności według CVE, punktacja istotności według CVSS, a proces testowania zgodnie z wytycznymi NIST SP 800-115 (Technical Guide to Information Security Testing and Assessment).

Ograniczenia oceny

- Skan nieuwierzytelniony zapewnia widoczność wyłącznie z perspektywy zewnętrznej; skan authenticated ujawniłby dodatkowe podatności na poziomie systemu.
- Próg QoD $\geq 70\%$ w OpenVAS odfiltrowuje znaleziska o niższej pewności detekcji.
- Ocenę przeprowadzono na pojedynczym celu w środowisku laboratoryjnym; nie stanowi ona pełnego testu penetracyjnego.

4. Środowisko testowe

Cel (maszyna skanowana)

```
Hostname: metasploitable3-ubl404
OS:      Ubuntu 14.04 LTS
Kernel:  Linux 3.13.0-24-generic
Arch:    x86_64
Adapter: Host-Only · IPv4: 192.168.47.7/24
```

Maszyna atakująca (skaner)

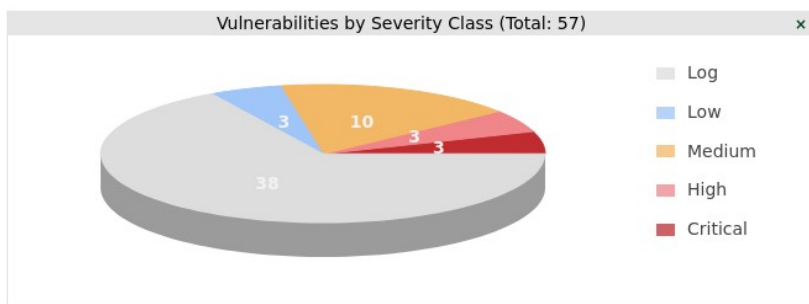
```
Hostname: kali
OS:      Kali GNU/Linux Rolling
Wirtualizacja: Oracle VirtualBox
Arch:    x86_64
Adapter: Host-Only · IPv4: 192.168.47.5/24
```

Obie maszyny znajdowały się w tej samej, izolowanej sieci host-only, co zapewniło separację celowo podatnego systemu od sieci zewnętrznej. Potwierdzenie topologii oraz faktycznego dotarcia skanu do celu przedstawiono w *Załącznikach (sekcja 9)*.

5. Wyniki — podatności według istotności

Poniższa tabela zestawia znaleziska obu skanerów. Wartości „b/d” oznaczają brak przypisanego identyfikatora CVE (znalezisko konfiguracyjne lub protokołowe).

Severity	OpenVAS	Nessus
Critical	• CVE-2015-3306 — CVSS 10.0 • CVE-2018-7600 — CVSS 10.0	• CVE-2015-3306 — CVSS 10.0 • CVE-2018-7600 — CVSS 10.0
High	• CVE-2014-3704 — CVSS 7.5 • CVE-2020-36915 — CVSS 7.5 • CVE b/d — CVSS 7.5	• CVE-2014-3704 — CVSS 7.5 • CVE-2016-2183 (Sweet32) — CVSS 7.5
Medium	• CVE-2012-6708 — 6.1 • CVE b/d — 5.3 (x2) • CVE-2017-16894 — 5.0 • CVE-2011-3730 — 5.0 • CVE b/d — 5.0 / 4.8 (x2) • CVE-2011-4969 — 4.3 • CVE b/d — 4.3	• SSL Certificate Cannot Be Trusted — 6.5 • SSL Self-Signed Certificate — 6.5 • TLS 1.0 / TLS 1.1 Deprecated — 6.5 • CVE-2001-0731 — 5.3 • CVE-2023-48795 (Terrapin) — 5.9 • SMB Signing not required — 5.3 • SSH Weak Algorithms — 4.3
Low	• CVE b/d — 2.6 (x2) • CVE-1999-0524 — 2.1	• CVE-2008-5161 — 3.7 • SSH Weak Key Exchange — 3.7 • SSH Weak MAC — 2.6 • CVE-1999-0524 — 2.1



Rys. 1. Rozkład podatności według istotności — OpenVAS (łącznie 57 znaleźsk).

6. Analiza wybranych podatności

CVE-2015-3306 — ProFTPD mod_copy (CVSS 10.0)

Dotknięte oprogramowanie: serwer ProFTPD 1.3.5 (do 1.3.5a / 1.3.6rc1), moduł mod_copy.

Wektor i działanie: nieuwierzytelniony atakujący łączy się z usługą FTP i za pomocą pary komend SITE CPFR / CPTO kopiuje dowolny plik w obrębie systemu plików dostępnego dla procesu ProFTPD. Operacja wykonuje się z uprawnieniami procesu serwera, co pozwala odczytać wrażliwe pliki oraz zapisać pliki w wybranym miejscu.

Skutki: najgroźniejszy scenariusz to zdalne wykonanie kodu — atakujący kopiuje spreparowany plik (np. webshell) do katalogu obsługiwanego przez serwer WWW współdzielący hosta, a następnie uruchamia go przez przeglądarkę. Pełny wpływ na poufność i integralność, pośrednio na dostępność.

Naprawa: aktualizacja do ProFTPD 1.3.5a lub nowszej; jeśli mod_copy nie jest potrzebny — wyłączenie go w konfiguracji.

CVE-2018-7600 — Drupalgeddon2 (CVSS 10.0)

Dotknięte oprogramowanie: Drupal core — wersje przed 7.58, 8.x przed 8.3.9, 8.4.x przed 8.4.6 oraz 8.5.x przed 8.5.1.

Przyczyna: niewystarczająca walidacja danych wejściowych w Form API. Drupal używa tzw. renderable arrays — tablic z właściwościami poprzedzonymi znakiem # (np. #post_render, #lazy_builder, #pre_render), które sterują procesem renderowania. Do niektórych endpointów można było przekazać dane trafiające bezpośrednio do tych struktur (CWE-20).

Wektor i działanie: nieuwierzytelniony atakujący wysyła żądanie (typowo do endpointów takich jak /user/register czy reset hasła) zawierające spreparowane elementy tablicy formularza z właściwościami #. Podczas renderowania Drupal wywołuje wskazaną funkcję i wykonuje kod atakującego.

Skutki: pełne, nieuwierzytelnione RCE — przejęcie witryny i serwera, kradzież danych, osadzenie backdoora. Luka była masowo wykorzystywana (kryptominery, botnety) w ciągu dni od ujawnienia.

Naprawa: aktualizacja do wersji załatanych (7.58 / 8.3.9 / 8.4.6 / 8.5.1) lub nowszych.

7. Środki zaradcze

CVE-2015-3306 (ProFTPD)

1. **Właściwa naprawa:** aktualizacja ProFTPD do wersji 1.3.5a lub nowszej.
2. **Kontrola kompensacyjna:** jeśli aktualizacja nie może być wykonana od razu — zablokowanie podatnych komend w konfiguracji serwera:

```
<Limit SITE_CPFR SITE_CPT0>
    DenyAll
</Limit>
```

3. **Weryfikacja i wykrywanie kompromitacji:** potwierdzić wersję w bannerze; sprawdzić, czy SITE CPFR / CPTO zwraca odmowę; przejrzeć logi pod kątem wcześniejszych wywołań tych komend oraz nietypowych plików w katalogach WWW.

CVE-2018-7600 (Drupal)

4. **Właściwa naprawa:** aktualizacja Drupala do 7.58 / 8.3.9 / 8.4.6 / 8.5.1 lub nowszej. Jeśli pełna aktualizacja jest niemożliwa od razu — nałożenie oficjalnego patcha bezpieczeństwa.
5. **Kontrola kompensacyjna:** reguła WAF blokująca żądania zawierające parametry z kluczami poprzedzonymi znakiem # oraz ograniczenie dostępu do endpointów typu /user/register i /user/password.
6. **Założenie możliwej kompromitacji:** luka była masowo eksploatowana i figuruje w katalogu CISA KEV. Jeśli witryna była wystawiona i niezatarta, należy przeprowadzić threat hunting: szukać webshelli i nieznanych plików w katalogu WWW, zmodyfikowanych zadań cron, nowych kont administratora, nietypowego ruchu wychodzącego. Przy podejrzeniu włamania — rotacja wszystkich sekretów (klucze, hasła, dane dostępu do bazy).

8. Wnioski

Stan systemu

Skanowanie wykazało, że host Metasploitable 3 zawiera liczne podatności o wysokiej istotności — co jest zgodne z jego przeznaczeniem jako celowo podatnej maszyny treningowej. Najpoważniejsze znaleziska to dwie podatności umożliwiające zdalne wykonanie kodu (RCE) o maksymalnej istotności CVSS 10.0.

Najpewniejsze znaleziska

Za najbardziej wiarygodne uznano podatności potwierdzone przez oba niezależne skanery i jednocześnie zgodne z profilem celu:

- **CVE-2015-3306** (ProFTPD, mod_copy) — RCE poprzez komendy SITE CPFR/CPTO.
- **CVE-2018-7600** (Drupalgeddon2) — nieuwierzytelnione RCE w Drupal core.

Zgodność dwóch źródeł oraz weryfikacja względem oprogramowania obecnego na celu czynią te znaleziska najpewniejszymi i priorytetowymi.

Odrzucony wynik fałszywie dodatni (false positive)

Podatność **CVE-2026-35905**, mimo zgłoszenia przez oba skanery, została po weryfikacji w źródle MITRE odrzucona jako fałszywie dodatnia. Dotyczy ona urządzeń sieciowych CPE firmy T3 Technology (routery abonenckie) i nie może dotyczyć systemu Ubuntu 14.04. Przypadek ten potwierdza kluczową zasadę: **potwierdzenie znaleziska przez wiele skanerów nie zastępuje weryfikacji względem kontekstu celu.** Skaner dostarcza kandydatów do analizy, a nie ostatecznego werdyktu.

Rozbieżność między skanerami

Oba narzędzia dały różne wyniki (OpenVAS: 3/3/10/3; Nessus: 3/2/8/4) wskutek odmiennych baz testów, polityk i progów detekcji. Nessus wyeksponował dodatkowo istotne podatności kryptograficzne (m.in. Sweet32 — CVE-2016-2183, Terrapin — CVE-2023-48795, przestarzałe TLS 1.0/1.1), słabiej reprezentowane w wynikach OpenVAS. Wniosek praktyczny: w zarządzaniu podatnościami należy korzystać z wielu źródeł i korelować ich wyniki, nie polegając na pojedynczym skanerze.

Rekomendacja priorytetyzacji

Naprawę należy prowadzić według realnego ryzyka, nie wyłącznie według wartości CVSS: w pierwszej kolejności dwie podatności RCE (ProFTPD, Drupal) jako umożliwiające pełne przejęcie systemu, następnie podatności kryptograficzne i konfiguracyjne wykazane przez Nessus.

9. Plan retestu

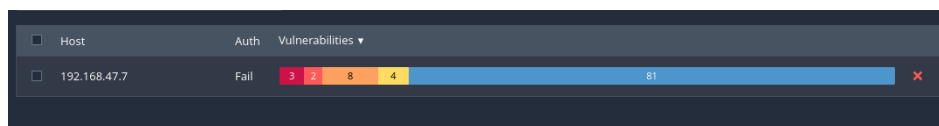
Po wdrożeniu środków zaradczych należy przeprowadzić skan weryfikacyjny (retest) tymi samymi narzędziami (OpenVAS „Full and fast”, Nessus „Basic Network Scan”) na tym samym celu 192.168.47.7. Kryteria zaliczenia:

- **CVE-2015-3306 (ProFTPD):** w bannerze usługi FTP widoczna wersja $\geq 1.3.5a$; SITE CPFR/CPTO zwraca odmowę; skaner nie zgłasza już podatności.
- **CVE-2018-7600 (Drupal):** potwierdzona aktualizacja do wersji załatanej; skaner nie wykazuje podatności; brak oznak wcześniejszej kompromitacji.
- **Podatności kryptograficzne (Nessus):** potwierdzenie wyłączenia przestarzałych protokołów (TLS 1.0/1.1) i słabych algorytmów.
- **Porównanie liczbowe:** rozkład severity po retestcie zestawiony z wynikiem pierwotnym w celu udokumentowania redukcji ryzyka.

Retest należy powtarzać po każdej istotnej zmianie konfiguracji oraz cyklicznie (np. kwartalnie), zgodnie z praktyką ciągłego zarządzania podatnościami.

10. Załączniki / Dowody

Poniższe materiały stanowią dowód przeprowadzenia oceny oraz poprawności środowiska testowego.



Zał. 1. Nessus — rozkład podatności hosta 192.168.47.7 (3 / 2 / 8 / 4 + 81 Info).

```
vagrant@metasploitable3-ub1404:~$ sudo netstat -antp | grep 192.168.47.5
tcp        0      0 192.168.47.7:3306    192.168.47.5:59479  TIME_WAIT   -
tcp        0      0 192.168.47.7:22      192.168.47.5:51965  ESTABLISHED 2654/sshd: unknown
tcp        0      0 192.168.47.7:6697    192.168.47.5:33565  TIME_WAIT   -
vagrant@metasploitable3-ub1404:~$ sudo netstat -antp | grep 192.168.47.5
tcp        0      0 192.168.47.7:631     192.168.47.5:40533  TIME_WAIT   -
tcp        0      0 192.168.47.7:3306    192.168.47.5:59479  TIME_WAIT   -
tcp        0      0 192.168.47.7:445     192.168.47.5:48737  ESTABLISHED 2663/smbd
tcp        0      0 192.168.47.7:6697    192.168.47.5:33565  TIME_WAIT   -
tcp6       0      0 192.168.47.7:8080    192.168.47.5:35775  TIME_WAIT   -
tcp6       0      0 192.168.47.7:8080    192.168.47.5:43177  TIME_WAIT   -
tcp6       0      0 192.168.47.7:80      192.168.47.5:54223  TIME_WAIT   -
tcp6       0      0 192.168.47.7:80      192.168.47.5:57999  TIME_WAIT   -
tcp6       0      0 192.168.47.7:8080    192.168.47.5:45931  TIME_WAIT   -
tcp6       0      0 192.168.47.7:8080    192.168.47.5:38859  TIME_WAIT   -
tcp6       0      0 192.168.47.7:8080    192.168.47.5:34445  TIME_WAIT   -
tcp6       0      0 192.168.47.7:80      192.168.47.5:48605  TIME_WAIT   -
tcp6       0      0 192.168.47.7:8080    192.168.47.5:39573  TIME_WAIT   -
tcp6       0      0 192.168.47.7:8080    192.168.47.5:42823  TIME_WAIT   -
tcp6       0      0 192.168.47.7:80      192.168.47.5:39629  TIME_WAIT   -
tcp6       0      0 192.168.47.7:8080    192.168.47.5:47529  TIME_WAIT   -
tcp6       0      0 192.168.47.7:8080    192.168.47.5:45029  TIME_WAIT   -
tcp6       0      0 192.168.47.7:80      192.168.47.5:43757  TIME_WAIT   -
tcp6       0      0 192.168.47.7:80      192.168.47.5:52575  TIME_WAIT   -
tcp6       0      0 192.168.47.7:80      192.168.47.5:55657  TIME_WAIT   -
tcp6       0      0 192.168.47.7:80      192.168.47.5:53109  TIME_WAIT   -
vagrant@metasploitable3-ub1404:~$ sudo netstat -antp | grep 192.168.47.5
tcp        0      0 192.168.47.7:631     192.168.47.5:40533  TIME_WAIT   -
tcp        0      0 192.168.47.7:445     192.168.47.5:52551  ESTABLISHED 2667/smbd
tcp        0      0 192.168.47.7:3306    192.168.47.5:59479  TIME_WAIT   -
tcp        0      0 192.168.47.7:6697    192.168.47.5:33565  TIME_WAIT   -
```

Zał. 2. netstat na maszynie celu — aktywne połączenia z adresu skanera 192.168.47.5 (potwierdzenie dotarcia skanu do usług: SSH, HTTP, SMB, MySQL, IRC).

```

(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 85236sec preferred_lft 85236sec
    inet6 fd17:625c:f037:2:8c0f:fabf:8d9b:37b3/64 scope global dynamic noprefixroute
        valid_lft 86241sec preferred_lft 14241sec
    inet6 fe80::3432:5186:56d:54c0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:fc:e3:c6 brd ff:ff:ff:ff:ff:ff
    inet 192.168.47.5/24 brd 192.168.47.255 scope global dynamic noprefixroute eth1
        valid_lft 336sec preferred_lft 336sec
    inet6 fe80::f038:387e:d4d4:50a3/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
(kali@kali)-[~]
$

```

ZaŁ. 3. Konfiguracja sieci Kali (skaner) — interfejs host-only eth1: 192.168.47.5/24.

```

vagrant@metasploitable3-ub1404:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:2e:a0:6f brd ff:ff:ff:ff:ff:ff
    inet 192.168.47.7/24 brd 192.168.47.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe2e:a06f/64 scope link
        valid_lft forever preferred_lft forever
3: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    link/ether 02:42:80:cf:97:77 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:80ff:fecf:9777/64 scope link
        valid_lft forever preferred_lft forever
5: veth69b2410: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master docker0 state UP group default qlen 1000
    link/ether b2:16:ae:b9:c9:a3 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::b016:aef:f9eb9:c9a3/64 scope link
        valid_lft forever preferred_lft forever
vagrant@metasploitable3-ub1404:~$

```

ZaŁ. 4. Konfiguracja sieci Metasploitable 3 (cel) — interfejs host-only: 192.168.47.7/24.